Introduction à la cybersécurité

Corrigé d'examen

Source : examen-2025-06-13.pdf · 20 questions

Le nom du fichier indique le 13 juin 2025 ; l'en-tête affiche le 24 janvier 2025, série A. Le corrigé suit le fichier fourni.

Question 1 · A, B, C Un justificatif classique repose sur la connaissance d'un secret, la possession d'un objet ou une caractéristique inhérente à la personne.

Ch. 4, Credentials — catégories de facteurs, p. 218 du PDF

Question 2 · A, G L'hameçonnage détourne la confiance au moyen d'un message trompeur. Les cas explicites sont l'usurpation par e-mail et le faux SMS, aussi appelé smishing.

À noter : B ou C peuvent accompagner une campagne de phishing, mais une pièce jointe infectée ou un vol d'identité ne suffisent pas à établir la présence du leurre.

Ch. 1, Exemple de menace : phishing, p. 20 du PDF

Question 3 · A, B, C, F Dans le scénario du cours, l'attaquant compromet des machines, choisit la cible, active ces machines et provoque une surcharge par l'envoi distribué de requêtes.

Ch. 1, Disponibilité — exemple DDoS, p. 34 du PDF

Question 4 · D, F La clé privée reste secrète. Son titulaire signe le message avec elle ; la vérification publique permet alors de détecter une modification. En RSA pour la confidentialité, la clé privée déchiffre.

À noter : B serait défendable au sens large où signer participe à l'authentification. Pour un message déjà signé, l'opération de vérification se fait avec la clé publique ; c'est ce sens qui conduit à ne pas cocher B.

Ch. 2, Cryptographie à clé publique et signatures numériques, p. 138–142 et 146–151 du PDF

Question 5 · A, C Un condensat de référence authentique permet de repérer une modification. Une signature numérique vérifiée avec la bonne clé publique protège aussi l'intégrité. Un simple hash joint au message sans protection peut être remplacé.

Ch. 1, Intégrité, p. 60 du PDF ; ch. 2, Hachage et signatures, p. 76 et 146–150

Question 6 · A, C Avec un chiffrement symétrique sûr, le texte chiffré ne permet pas de retrouver efficacement la clé ni le clair sans le secret. La même clé sert au chiffrement et au déchiffrement.

Ch. 2, Principe du chiffrement et chiffrements symétriques, p. 77 et 119 du PDF

Question 7 · A, C Le système doit résister sans la clé et rester utilisable. Seule la clé doit être secrète ; cacher le fonctionnement du système n'est pas la garantie recherchée.

Ch. 1, Principes de Kerckhoffs, p. 67 du PDF

Question 8 · A, C, D Prouver la possession d'un secret sans le livrer évite notamment qu'un administrateur malveillant récupère ce secret. Dans l'exemple, un défi frais est signé puis vérifié à l'aide de la clé publique.

Ch. 4, Authentification standard, preuve sans divulgation et défi-réponse, p. 222–223 et 259 du PDF

Question 9 · A, C, E On ne fait pas confiance à un équipement simplement parce qu'il est interne. Diviser le réseau en sous-réseaux distincts et contrôler les échanges limite la propagation après une intrusion.

Ch. 5, Topologie — Zero Trust et segmentation, p. 424–425 du PDF

Question 10 · B, C Le chiffrement se fait avant l'envoi sur l'appareil de l'expéditeur. Seules les extrémités autorisées détiennent les clés de déchiffrement ; un serveur intermédiaire n'accède pas au clair.

À noter : C se comprend comme « côté client plutôt que côté serveur ». En messagerie, le destinataire autorisé peut aussi déchiffrer.

Ch. 5, Chiffrement de bout en bout, p. 392–397 du PDF

Question 11 · B DNSSEC authentifie l'origine des données DNS et détecte leur modification par signature. Il ne chiffre pas les requêtes et n'empêche pas à lui seul une saturation.

Ch. 5, Sécurité du DNS — DNSSEC et conclusions, p. 488 et 527–528 du PDF

Question 12 · D, E Le VPN peut faire apparaître l'adresse de sa sortie plutôt que celle de l'utilisateur. Un VPN d'accès distant peut aussi intégrer virtuellement l'appareil au réseau protégé et lui donner une adresse interne.

À noter : A serait vrai si le « serveur auquel il se connecte » désigne précisément l'autre extrémité du tunnel VPN ; ce n'est pas une garantie jusqu'à tout serveur tiers après la sortie du tunnel.

Ch. 5, Tunnels — principe des VPN, p. 390 du PDF ; limites de la confidentialité des tunnels, p. 392

Question 13 · A, C, D OAuth délègue l'accès à une ressource par jeton. Le fournisseur peut authentifier l'utilisateur pendant le flux, mais OAuth seul ne fournit pas au client une authentification normalisée de l'utilisateur.

À noter : F décrit plutôt un flux OpenID Connect construit sur OAuth 2.0 si l'objectif est de connecter l'utilisateur à l'application ; les identifiants ne sont alors pas communiqués à cette dernière.

Ch. 4, OAuth — principe et flux d'autorisation, p. 356–358 du PDF

Question 14 · A Une autorité de certification atteste le lien entre une identité et une clé publique. Le certificat permet à un tiers de vérifier cette association avant de faire confiance à la clé.

Ch. 3, Principe de certification et objectifs de la PKI, p. 181–185 du PDF

Question 15 · B, C, D, F Le certificat indique une période de validité, un numéro de série propre à l'émetteur, l'identité du titulaire et l'algorithme de signature. Il porte la signature de l'émetteur et ne révèle pas la clé privée du titulaire.

À noter : E et G sont le même distracteur imprimé. Pour C, l'unicité du numéro est définie pour une autorité donnée (RFC 5280, §4.1.2.2).

Ch. 3, Structure d'un certificat X.509 v3, p. 185 du PDF

Question 16 · B, D, E Le certificat racine identifie l'autorité racine. Une liste de racines distribuée avec le navigateur ou le système fournit les ancres de confiance de la PKI.

Ch. 3, Autorités racines et chaîne de confiance, p. 201–205 du PDF

Question 17 · A, B, C, D La validation peut échouer si la chaîne ne mène à aucune autorité reconnue, si la date n'est pas valide, si le certificat est révoqué ou si sa signature ne se vérifie pas.

À noter : Une interception peut entraîner l'un de ces échecs si un certificat de substitution est présenté. E ne désigne pas un contrôle indépendant, et certains certificats frauduleux ont même été acceptés après compromission d'une CA (p. 202).

Ch. 3, X.509, révocation et chaîne de confiance, p. 185, 196–197 et 201–205 du PDF

Question 18 · A, D, G Le JWT signé présenté en cours contient en-tête, charge utile et signature. Stocké côté client, par exemple en cookie sécurisé, il accompagne les requêtes ultérieures sans nouvelle saisie du mot de passe.

À noter : Un stockage en localStorage est possible, mais expose le jeton à un script injecté. La structure à trois parties est celle du JWS du cours. Un JWT peut aussi encapsuler des claims chiffrés en JWE (RFC 7519), sans être le mécanisme qui chiffre la connexion.

Ch. 4, JWT — principe, structure et flux, p. 316–319 du PDF

Question 19 · E Une KDF dérive une clé à partir d'un secret ou étire le matériel de clé. Elle ne chiffre pas elle-même les données, ne stocke pas de clés et ne remplace pas l'authentification.

Ch. 3, Échange de clés — fonction de dérivation, p. 176–178 du PDF

Question 20 · B, D, G, H WebAuthn utilise une paire de clés par inscription. Un authentificateur matériel ou logiciel conserve la clé privée et signe le défi ; le serveur ne reçoit que la clé publique et les preuves. Il peut servir sans mot de passe.

Ch. 4, WebAuthn — principe, inscription et authentification, p. 329–331 et 345 du PDF